ZetaERP — Manual Bug-Testing SOP

Part 1 of N — Authentication & Onboarding (Login, Sign-up, Onboarding, Google Sign-in)

Document	QA-SOP-01 — Login & Onboarding
Product	ZetaERP / Zenith (multi-tenant POS / ERP)
Environment under test	Production — https://erp.zetaclantech.com
Scope of this part	Public authentication & tenant onboarding only. POS, billing, inventory, settings are covered in later parts.
Audience	Manual QA tester (no code knowledge assumed)
Document owner	Platform / Solo-dev
Status	Active
Last updated	2026-06-30

CONTENTS

1. Purpose

2. Critical rules for the tester (read before starting)

3. Test environment & preconditions

4. Test data

5. Conventions & severity

6. Flow map (what you are testing)

7. LOGIN — Test Cases

- 7.1 Happy path
- 7.2 Organization-ID validation (ZetaERP-specific gate)
- 7.3 Wrong-credential & negative cases
- 7.4 Two-factor authentication (2FA / OTP)
- 7.5 Password change required & expired credentials
- 7.6 Forgot / reset password
- 7.7 Remember Me & session
- 7.8 "Continue with Google"
- 7.9 Login — UI / layout / accessibility

8. ONBOARDING / SIGN-UP — Test Cases

- 8.1 Happy path
- 8.2 Subdomain field
- 8.3 Email & password (admin account)
- 8.4 GSTIN & tax
- 8.5 Country / Industry / Plan
- 8.6 Google-routed onboarding (passwordless)
- 8.7 Onboarding — UI / layout / accessibility
- 8.8 Onboarding — security & abuse

9. Cross-flow / regression checks (run after the above)

10. Known areas to probe hardest (tester's attention map)

11. Test run sheet (copy per browser/device)

12. Defect report template

13. Teardown (mandatory)

14. Known defects & resolutions (from the hardening pass on 2026-06-30)

1. Purpose

This Standard Operating Procedure tells a tester **exactly how to manually test the Login and Onboarding journeys end-to-end (A→Z)** — the happy paths, every field validation, the edge cases, the security cases, and the visual/UI cases — and **how to record a defect** when something behaves differently from the *Expected Result*.

Follow it top-to-bottom in a single session. Do **not** skip cases because "it obviously works" — the value of an SOP is the cases that *aren't* obvious.

---

2. Critical rules for the tester (read before starting)

> ⚠️ **This is a LIVE commercial system with real paying tenants.**

1. **Never test against the live flagship tenant** (MARUTHI / Organization ID `100000`). Use only the disposable QA accounts created per this SOP.
2. **Every tenant you create during testing must be cleaned up** (see §13 Teardown) or handed to the dev for deletion. A signup creates a full organization, an admin user, ledgers, and a receipt template — it is **not** a throwaway row.
3. **Never share, screenshot, or paste real passwords, OTP codes, or Google tokens** into the bug tracker. Mask them (e.g. `Pa****1!`).
4. If a test would **send a real email / SMS** (password reset, OTP), confirm the destination is a QA inbox you control — never a customer's address.
5. If you are unsure whether an action is reversible, **stop and ask the dev** before clicking.

---

3. Test environment & preconditions

Item	Value
Login URL	`https://erp.zetaclantech.com/Login`
Onboarding (wizard) URL	`https://erp.zetaclantech.com/get-started`
Legacy signup URL	`https://erp.zetaclantech.com/signup`
Sign-in landing page	`https://erp.zetaclantech.com/signin`
Successful login lands on	`https://erp.zetaclantech.com/qapps/zenith/Dashboard`
Successful onboarding lands on	`https://erp.zetaclantech.com/apps/zenith`

Browsers to cover (run the full pass on at least the first; spot-check the rest):

- Desktop Chrome (latest) — primary
- Desktop Safari (Mac) and Windows Edge
- Mobile Safari (iPhone) and Mobile Chrome (Android)

Devices / viewports for the UI cases: 1920×1080, 1366×768, iPad (768/1024), iPhone (390×844), small Android (360×740).

Tools: browser DevTools (Network + Console tabs), an incognito/private window (for "logged-out" state), and a QA email inbox.

---

4. Test data

Create these as you go; record the exact values you used in the *Actual* column of your run sheet.

Label	Use	Example pattern
`QA_TENANT_A`	A fresh tenant you create in the Onboarding tests	Business "QA Alpha Store", subdomain `qaalpha01`
`QA_TENANT_B`	A second tenant, to test "duplicate" rules	subdomain `qabeta01`
Valid password	Meets policy	`Qa-test1!` (≥8 chars, ≥1 digit, ≥1 symbol)
Weak passwords	Negative tests	`abc` / `abcdefgh` / `12345678`

Label	Use	Example pattern
Valid GSTIN	15 chars	use a real-format 15-char string supplied by the dev — **do not invent a registered number**
Google QA account	For Google sign-in	a Gmail address you control

> 📌 **Org ID = uppercase subdomain.** If you sign up with subdomain `qaalpha01`, your Organization ID for login is `QAALPHA01`.

---

5. Conventions & severity

Case Type: `FUNC` (functional) · `EDGE` (edge/boundary) · `UI` (visual/layout) · `A11Y` (accessibility) · `SEC` (security) · `PERF` (performance).

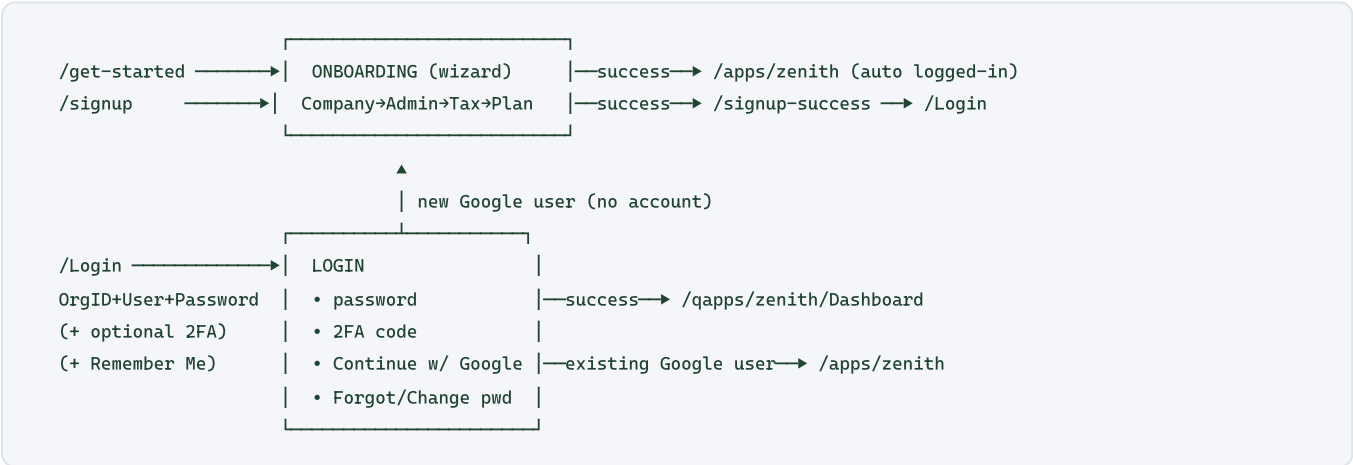
Severity:

Sev	Meaning	Example
S1 — Critical	Blocks login/signup for everyone, data loss, or security hole	Anyone can log in without an Org ID; password shown in plain text on the wire
S2 — High	Major flow broken or wrong, with a workaround	Valid user cannot log in; duplicate subdomain accepted
S3 — Medium	Wrong behaviour, limited impact	Error message misleading; validation only server-side
S4 — Low	Cosmetic / minor UX	Button misaligned on iPhone; tooltip typo

How to log a defect (§12 has the template): every defect needs the **Case ID**, steps, **expected vs actual**, browser/device, a screenshot, and (for anything on the wire) the relevant **Network/Console** capture.

---

6. Flow map (what you are testing)



---

7. LOGIN — Test Cases

Screen: `/Login`. **Required inputs:** Organization ID, Username, Password. Optional: 2FA code, Remember Me. The Google button appears **only** when Google sign-in is configured for the platform.

7.1 Happy path

ID	Type	Title	Steps	Test data	Expected result	Sev
LOGIN-001	FUNC	Valid login	1. Open `/Login` in incognito 2. Enter Org ID, Username, Password 3. Submit	A known-good QA tenant admin	Lands on `/qapps/zenith/Dashboard`; user is authenticated; no error banner	S1

ID	Type	Title	Steps	Test data	Expected result	Sev
LOGIN-002	FUNC	Login form renders fully	Open `/Login`	—	Org ID, Username, Password fields, submit button, "Forgot/Change password" affordance, and "Create account / Sign up" link all visible	S2
LOGIN-003	FUNC	Password is masked	Type into Password	`Qa-test1!`	Characters render as dots; not visible in the field	S2
LOGIN-004	FUNC	Already-authenticated redirect	Log in, then manually browse to `/Login` again	—	Auto-redirects to `/qapps/zenith/Dashboard` ; the login form is **not** shown to a logged-in user	S3
LOGIN-020	SEC	**No username enumeration on failed login**	With a valid Org ID, submit (a) a **valid** username + **wrong** password, then (b) a **nonexistent** username	**[Fixed 49daf47]** Both return the **byte-identical** generic message **"The username or password you entered is incorrect."** — the app never reveals whether the username exists. (Previously the valid-user case showed "...incorrect for username `<x>` ", confirming the account.) Note the fix uses `clearAll()` because Moqui adds the revealing text as a *public message*, not an error	S1	

7.2 Organization-ID validation (ZetaERP-specific gate)

> Login is **not** just username+password — after the password check, the system verifies the **Organization ID** and that the user is an *employee member* of that org. These are the highest-value cases on this screen.

ID	Type	Title	Steps / data	Expected result	Sev
LOGIN-010	FUNC	Missing Org ID	Correct username+password, **leave Org ID blank**	Login is rejected; user is logged back out; message **"Organization ID is required"**	S1
LOGIN-011	FUNC	Invalid Org ID	Correct username+password, Org ID = `NOSUCHORG`	Rejected + logged out; message **"Invalid Organization ID"**	S2
LOGIN-012	SEC	Valid Org ID but user not a member	User from Tenant A, but enter Tenant B's Org ID (both correct passwords)	**FIXED (D-1):** rejected + logged out with **"User does not belong to this organization"**; bounced back to the login page (does not reach the dashboard). Platform super-admins are exempt by design (LOGIN-012b)	S1
LOGIN-012b	SEC	Super-admin exemption	Log in as a platform super-admin (`ADMIN` group, e.g. john.doe) with any Org ID	Allowed (admins operate cross-tenant); the admin is **not** pinned to that org's active-organization	S2
LOGIN-013	EDGE	Org ID case-insensitivity	Enter the Org ID in lowercase (`maruthi` / `qaalpha01`)	**FIXED:** accepted — login normalises the Org ID to uppercase (tries as-typed, then uppercased). Lower/mixed case no longer fails the lookup	S2
LOGIN-014	EDGE	Org ID with spaces / trailing space	`QAALPHA01`	Trimmed and accepted, or a clear error — never a silent 500	S3
LOGIN-015	SEC	Org isolation after login	Log in to Tenant A, then via URL try to view Tenant B data	No cross-tenant data is visible; `ACTIVE_ORGANIZATION` is bound to Tenant A only	S1

7.3 Wrong-credential & negative cases

ID	Type	Title	Data	Expected result	Sev
LOGIN-020	FUNC	Wrong password	Valid user, wrong password	Generic failure; **must not** reveal whether the username exists	S1
LOGIN-021	FUNC	Unknown username	`nobody@example.com`	Generic failure message; no stack trace	S2
LOGIN-022	FUNC	All fields blank	Submit empty form	Validation blocks submit (or a clear "required" message); no server error	S3

ID	Type	Title	Data	Expected result	Sev
LOGIN-023	SEC	SQL/script injection in fields	Username `' OR '1'='1`, password `<script>alert(1)</script>`	Treated as literal text; login fails; **no** alert pops, no SQL error	S1
LOGIN-024	EDGE	Very long inputs	1,000-char username/password	Handled gracefully (rejected/trimmed), no crash	S4
LOGIN-025	EDGE	Leading/trailing spaces in username	`user@qa.com`	Define & record: trimmed or rejected consistently	S3
LOGIN-026	EDGE	Unicode / emoji in fields	`tÉst😀@qa.com`	No crash; graceful failure	S4
LOGIN-027	SEC	Rapid repeated failures (lockout / throttle)	Enter a **wrong password 3 times** for a test user	Account is **locked for 5 minutes** after 3 successive failures (framework policy `max-failures=3`, `disable-minutes=5`); the 4th attempt fails even with the correct password until the window passes. Note for product: 3/5 may be tight for fat-fingering cashiers — tune in config if needed	S2

7.4 Two-factor authentication (2FA / OTP)

> Only applies to a user account that has a second factor enabled. Ask the dev to enable 2FA on a QA account first.

ID	Type	Title	Steps	Expected result	Sev
LOGIN-030	FUNC	2FA prompt appears	Log in with a 2FA-enabled QA user	After password is accepted, a **code entry** step appears (user is in "pre-auth", not yet fully logged in)	S2
LOGIN-031	FUNC	Send OTP	Trigger "send code" for the chosen factor	Code is sent to the configured factor; UI confirms	S2
LOGIN-032	FUNC	Correct code	Enter the valid code	Login completes → Dashboard	S1
LOGIN-033	FUNC	Wrong code	Enter a wrong code	Message **"Authentication code is not valid"**; stays on code step; not logged in	S1
LOGIN-034	FUNC	Missing code	Submit with code blank while pre-auth	Message **"Authentication code required for user ..."**	S3
LOGIN-035	EDGE	Expired/old code	Wait past validity, then enter	Rejected as invalid	S3
LOGIN-036	FUNC	Cancel pre-auth	Use the "remove pre-auth / start over" affordance	Returns to a clean login form; previous pre-auth state cleared	S3

7.5 Password change required & expired credentials

ID	Type	Title	Steps	Expected result	Sev
LOGIN-040	FUNC	Forced change on login	Log in as a user flagged "must change password"	Auto-switches to the **Change Password** tab	S2
LOGIN-041	FUNC	Expired credentials	Log in as a user with expired credentials	Routed to Change Password tab	S2
LOGIN-042	FUNC	Successful change → auto login	Complete new password + verify	Password updates and the user is logged in **without** re-entering everything	S2
LOGIN-043	FUNC	New ≠ Verify	New password and Verify differ	Rejected with a clear mismatch message	S3
LOGIN-044	FUNC	New password fails policy	New password `abcdefgh` (no digit/symbol)	Rejected; states the policy (≥8 chars, ≥1 digit, ≥1 symbol)	S2

7.6 Forgot / reset password

ID	Type	Title	Steps	Expected result	Sev
LOGIN-050	FUNC	Reset request (valid user)	Use "Forgot password", enter a QA username	A reset email is sent to that account's email; UI confirms without revealing account existence	S2
LOGIN-051	SEC	Reset request (unknown user)	Enter an unknown username	Same neutral confirmation — **must not** reveal that the account doesn't exist	S2
LOGIN-052	FUNC	Reset link works	Open the link from the email	Lands on Change Password with username (and reset code) pre-filled	S2
LOGIN-053	EDGE	Reset link reuse / expiry	Use the link twice / after expiry	Second use or expired link is rejected gracefully	S3

7.7 Remember Me & session

ID	Type	Title	Steps	Expected result	Sev
LOGIN-060	FUNC	Remember Me on	Log in with "Remember Me" ticked, close browser, reopen `/Login`	Auto-logged in and redirected to Dashboard; the active organization is restored	S2
LOGIN-061	FUNC	Remember Me off	Log in **without** ticking it, close & reopen	Login form is shown again (no auto-login)	S2
LOGIN-062	SEC	Remember-Me cookie is HttpOnly	DevTools → Application → Cookies → `moquiLoginKey`	Cookie is **HttpOnly**, path `/`; not readable from JS console (`document.cookie` does not show it)	S2
LOGIN-063	FUNC	Logout clears remember-me	Log in with Remember Me, then Logout	`moquiLoginKey` cookie is cleared; reopening `/Login` shows the form	S2
LOGIN-064	EDGE	Tampered remember-me cookie	Edit `moquiLoginKey` to garbage, reload `/Login`	Invalid key is ignored, cookie cleared, login form shown — no crash, no auto-login	S2
LOGIN-065	FUNC	Logout	Click Logout from inside the app	Session ends; visiting an app URL redirects to login	S2

7.8 "Continue with Google"

> The Google button is shown **only when** the platform has a real Google Client ID configured. If it's hidden, record "Google not configured — section skipped" and move on (that is the correct safe default).

ID	Type	Title	Steps	Expected result	Sev
LOGIN-070	FUNC	Button visibility	Open `/Login`	Google button shown only if configured; otherwise absent (no broken/empty box)	S3
LOGIN-071	FUNC	Existing Google-linked user	Click Google, pick a Gmail already linked (has Google binding)	Logs in passwordless → `/apps/zenith`	S2
LOGIN-072	FUNC	Brand-new Google user	Click Google with a Gmail that has **no** account	Routed to `/get-started` with name/email pre-filled (passwordless onboarding)	S2
LOGIN-073	SEC	Email exists but not Google-linked	Use a Gmail that matches an existing **password** account never linked to Google	**Blocked** with: *"An account already exists for … Please sign in with your password, then link Google from your account settings."* Google login is **not** silently granted	S1
LOGIN-074	SEC	Unverified Google email	A Google account whose email is not verified	Rejected: *"Your Google email is not verified."*	S2
LOGIN-075	EDGE	Google popup cancelled	Open Google chooser, close it	Returns to login cleanly; no error spam, no stuck spinner	S3
LOGIN-076	SEC	Tampered/garbage token	(Dev-assisted) POST `/Login/googleAuth` with a junk `credential`	Server rejects ("Could not verify…"/"Google sign-in failed"); no login granted	S1

7.9 Login — UI / layout / accessibility

ID	Type	Title	Check	Expected result	Sev
LOGIN-080	UI	Desktop layout	View at 1920 & 1366	Card centred, no overflow, fields aligned, branding correct	S4
LOGIN-081	UI	Mobile layout	iPhone 390px & Android 360px	**No horizontal scroll**; fields full-width and tappable; button reachable	S3
LOGIN-082	UI	Error banner	Trigger a failure	Error appears in a visible, dismissible banner; page doesn't jump/cover the form	S3
LOGIN-083	A11Y	Keyboard only	Tab through the form, submit with Enter	Logical tab order; Enter submits; visible focus ring on each field	S3
LOGIN-084	A11Y	Labels & autofill	Inspect fields	Each input has a label/placeholder; password field is `type=password`; browser password-manager autofill works	S4
LOGIN-085	UI	Slow-network feedback	Throttle to Slow 3G, submit	A pending/disabled state — no double-submit, no frozen UI with no feedback	S3
LOGIN-086	UI	Back button after login	Log in, press browser Back	Does **not** return to a usable login form / stale state; lands sensibly (Dashboard or re-redirect)	S3

---

8. ONBOARDING / SIGN-UP — Test Cases

Primary screen: `/get-started` (the multi-section wizard: **1. Company** → **Admin** → **2. Tax** → **3. Plan**). **Legacy:** `/signup` (same fields; on success shows the `/signup-success` confirmation page instead of auto-login).

Fields: Business Name*, Workspace URL / Subdomain*, Country (default India), Industry (default Retail), First Name*, Last Name*, Email* (becomes the login username), Phone, Password* (min 8), GSTIN (optional), Plan (default Starter). *= required.

8.1 Happy path

ID	Type	Title	Steps	Expected result	Sev
ONB-001	FUNC	Full email signup (wizard)	Open `/get-started`, fill all required fields with valid data, choose Starter, submit	Tenant + admin user created; user is **auto-logged-in** and lands on `/apps/zenith`	S1
ONB-002	FUNC	Legacy signup confirmation	Repeat via `/signup`	Lands on `/signup-success` showing **Organization ID** (uppercase subdomain), **Username** (email), and **subdomain.zetaclantech.com**, plus a "save your Org ID" notice and a **Go to Login** link	S2
ONB-003	FUNC	Page renders fully	Open `/get-started`	All three sections, the trial message ("14-day free trial · No credit card required"), and the "Already have an account? Sign in" link render	S2
ONB-004	FUNC	Defaults pre-selected	Inspect dropdowns on load	Country = India, Industry = Retail (General), Plan = Starter pre-selected	S3

8.2 Subdomain field

ID	Type	Title	Steps / data	Expected result	Sev
ONB-010	FUNC	Live availability check	Type a free subdomain, then a taken one (`qaalpha01` after creating Tenant A)	Real-time check shows available vs taken (the field calls a `checkSubdomain` lookup)	S2
ONB-011	FUNC	Duplicate subdomain blocked on submit	Submit with an already-used subdomain	Rejected: **"Subdomain '...' is already taken. Please choose another."**; no tenant created	S1
ONB-012	EDGE	Uppercase / mixed-case subdomain	Enter `QaAlpha02`	**FIXED:** canonicalised to lowercase (`qaalpha02`) for storage; Org ID becomes the uppercase form. Success page + login now agree	S2
ONB-013	EDGE	Subdomain with spaces/symbols	`qa alpha!` / `qa_alpha` / `qa-alpha` / `-qa` / `qa-` / `qa--b`	**FIXED:** rejected with "*Use 3-30 characters: lowercase letters, numbers and hyphens only (cannot start or end with a hyphen)*"; double hyphen → "*cannot contain two hyphens in a row*". `qa-alpha` (single internal hyphen) is allowed	S2

ID	Type	Title	Steps / data	Expected result	Sev
ONB-014	EDGE	Very short / very long subdomain	`ab` (2) and a 31-char string	**FIXED:** min 3 / max 30 enforced with the format message above	S3
ONB-015	EDGE	Reserved words	`www` , `admin` , `api` , `app` , `login` , `zeta` , `dashboard`	**FIXED:** blocked with "'...' *is reserved. Please choose another.*"	S3

8.3 Email & password (admin account)

ID	Type	Title	Data	Expected result	Sev
ONB-020	FUNC	Duplicate email blocked	Sign up with an email already used by another account	Rejected: **"An account with email '...' already exists."**; no tenant created	S1
ONB-021	EDGE	Invalid email format	`notanemail` , `a@b` , `a@@b.com`	Rejected with a clear "valid email" message (client and/or server)	S2
ONB-022	FUNC	Password too short	`abc` (under 8)	Rejected; policy now stated under the field: **≥8 chars, ≥1 number, ≥1 special char**	S2
ONB-023	EDGE	Password 8 letters only	`abcdefgh` (no digit/symbol)	Rejected. **FIXED:** the field now advertises the full rule up-front ("*At least 8 characters, including at least 1 number and 1 special character*"), so the rejection is no longer surprising. Confirm `Qa-test1!` passes and `abcdefgh` / `12345678` fail	S3
ONB-024	FUNC	Strong password accepted	`Qa-test1!`	Accepted	S2
ONB-025	UI	Password masking	Type into Password	Masked; optional show/hide toggle works if present	S4
ONB-026	SEC	Password not echoed back on error	Cause a validation error after typing a password	On reload, the password field is **not** pre-filled with the real value in the page source	S2

8.4 GSTIN & tax

ID	Type	Title	Data	Expected result	Sev
ONB-030	FUNC	Blank GSTIN allowed	Leave GSTIN empty, submit	Accepted (GSTIN is optional)	S2
ONB-031	FUNC	Wrong-length GSTIN	14 or 16 characters	Rejected: **"GSTIN must be exactly 15 characters, or leave it blank."**	S2
ONB-032	FUNC	Valid 15-char GSTIN	A dev-supplied 15-char value	Accepted; state code derived from the first 2 digits (CGST/SGST vs IGST). **Do not invent a real GSTIN**	S2
ONB-033	EDGE	Lowercase GSTIN	Enter in lowercase	Normalised to uppercase, accepted	S3
ONB-034	EDGE	GSTIN with spaces	`22AAAAA0000A1Z5`	Trimmed; length checked on the trimmed value	S3

8.5 Country / Industry / Plan

ID	Type	Title	Steps	Expected result	Sev
ONB-040	FUNC	Country list loads	Open Country dropdown	Populated list; India selectable; selection persists on validation error	S3
ONB-041	FUNC	Industry list loads	Open Industry dropdown	Populated; default Retail; selection persists	S3
ONB-042	FUNC	Plan options & limits	Open Plan dropdown	Each plan shows name + limits (e.g. "Starter (N users, N POS)"); Starter default	S3
ONB-043	UI	Native select on mobile	On mobile, open each dropdown	Falls back to the native mobile picker; usable (no broken custom widget)	S3

8.6 Google-routed onboarding (passwordless)

> Reached by clicking **Continue with Google** as a brand-new user (see LOGIN-072).

ID	Type	Title	Steps	Expected result	Sev
ONB-050	FUNC	Identity pre-filled	Arrive at `/get-started` from Google	Header reads "Signed in as — just a few business details."; First/Last/Email/**Password** fields are **hidden** (Google = passwordless)	S2
ONB-051	FUNC	Complete Google onboarding	Fill Business Name, subdomain, plan; submit	Tenant created, account **bound to the Google identity**, auto-logged-in to `/apps/zenith` — no password ever set	S2
ONB-052	FUNC	Later login is Google-only	Log out, return to `/Login`, click Google with the same Gmail	Logs in passwordless (it now has a Google binding)	S2
ONB-053	SEC	Session identity can't be spoofed	(Dev-assisted) Try to reach `/get-started` claiming a Google identity without the real Google flow	The pre-filled identity comes only from a verified Google token in session; cannot be forged via URL params	S1
ONB-054	EDGE	Abandon Google onboarding	Arrive from Google, then close the tab without submitting	No partial/orphan tenant is created; the email remains free to sign up again	S3

8.7 Onboarding — UI / layout / accessibility

ID	Type	Title	Check	Expected result	Sev
ONB-060	UI	Desktop two-column (legacy /signup)	View `/signup` at 1366+	Form + "What you get" panel align; no overlap	S4
ONB-061	UI	Mobile single-column	`/get-started` at 360–390px	**No horizontal scroll**; sections stack; inputs full-width; submit reachable	S3
ONB-062	UI	Section headers & order	Scan the wizard	Clear 1-Company / 2-Tax / 3-Plan grouping; logical top-to-bottom order	S4
ONB-063	UI	Required-field feedback	Submit with required blanks	Clear indication of which fields are missing; focus moves to the first error	S3
ONB-064	UI	Error preserves entered data	Cause one validation error	All other fields keep what you typed (except password) — you don't refill the whole form	S2
ONB-065	A11Y	Keyboard & labels	Tab through; inspect	Logical order, visible focus, every field labelled	S3
ONB-066	UI	Double-submit guard	Submit, then immediately click again	Only one tenant is created; button disables/shows progress	S2
ONB-067	PERF	Submit responsiveness	Time from submit to landing	Reasonable; a spinner/disabled state during the wait, not a dead page	S3
ONB-068	UI	Cross-link integrity	Click "Already have an account? Sign in/Log in"	Goes to `/Login`; and from Login the "Sign up" link returns here	S4

8.8 Onboarding — security & abuse

ID	Type	Title	Steps	Expected result	Sev
ONB-070	SEC	CSRF protection	(Dev-assisted) POST the register transition without the session token	Rejected (the register transition requires a session token)	S1
ONB-071	SEC	XSS in business name	Business Name = `<img src=x onerror=alert(1)>`	Stored/escaped as text; never executes in the success page, dashboards, or receipts later	S1
ONB-072	SEC	No secret leakage on success	Inspect `/signup-success` page source	Shows Org ID/username/subdomain only — **no password**, no internal IDs/tokens	S2
ONB-073	EDGE	Rapid repeat signups	Submit several tenants quickly	Each is isolated and consistent (or throttled); confirm with dev whether a rate limit exists	S2

ID	Type	Title	Steps	Expected result	Sev
ONB-074	SEC	Auth not required	Open `/get-started` and `/signup` logged-out	Pages load without login (they are public by design)	S3

9. Cross-flow / regression checks (run after the above)

ID	Type	Title	Expected result	Sev
XF-001	FUNC	Signup → Login round-trip	After ONB-002, log in at `/Login` with the new Org ID + email + password → reaches Dashboard	S1
XF-002	FUNC	New tenant starts clean & isolated	The new tenant's dashboard shows **its own** (empty) data — never MARUTHI's or another tenant's	S1
XF-003	FUNC	Org ID on success = Org ID at login	The Org ID shown on `/signup-success` is accepted at `/Login` **in any case** (login uppercases it; signup canonicalises the subdomain)	S2
XF-004	UI	Branding consistency	Login, signup, onboarding, success all carry consistent ZetaERP branding/styling	S4

10. Known areas to probe hardest (tester's attention map)

These are the spots most likely to hide defects in *this* part of the product — spend extra time here:

1. **Org-membership gate (LOGIN-012/012b):** *fixed* (§14 D-1). Re-test the full matrix — non-member blocked, invalid blocked, super-admin allowed, real tenant member allowed — and especially confirm a **real MARUTHI cashier still logs in**.
2. **Case-sensitivity of subdomain ↔ Org ID (ONB-012, LOGIN-013, XF-003):** *fixed* in this pass — regression-test that lower/mixed case Org IDs log in and that signup canonicalises to lowercase.
3. **Password policy (ONB-022/023):** *fixed* — confirm the field states the full rule and that letter-only passwords are rejected.
4. **Google email-collision policy (LOGIN-073):** must block, not silently link (verified correct in code).
5. **Tenant cleanup (every ONB case):** each successful signup is a real org — track them all.

11. Test run sheet (copy per browser/device)

Run info	
Tester	
Date	
Build / URL	https://erp.zetaclantech.com
Browser / OS	
Device / viewport	

Case ID	Status (Pass/Fail/Blocked/Skip)	Actual result	Defect ID
LOGIN-001			
…			
ONB-001			
…			

12. Defect report template

```
Defect ID:        ZE-AUTH-____
Linked Case ID:   LOGIN-0__ / ONB-0__
Title:            <short, specific>
Severity:         S1 / S2 / S3 / S4
Type:             FUNC / EDGE / UI / A11Y / SEC / PERF
Environment:      Prod — erp.zetaclantech.com | <browser> <version> | <device/viewport>
Preconditions:    <state, account used — mask secrets>
Steps to reproduce:
   1.
   2.
   3.
Expected result:  <from the SOP>
Actual result:    <what happened>
Evidence:         <screenshot/recording; Network+Console capture for wire issues>
Reproducibility:  Always / Intermittent (x of y)
Notes:            <Org ID, tenant subdomain, anything the dev needs — NO passwords/OTP/tokens>
```

---

13. Teardown (mandatory)

After the run:

1. **List every tenant you created** (business name + subdomain + admin email).
2. Hand the list to the dev for deletion **or** follow the agreed cleanup step — a signup creates an organization, an admin user, GST config, ledgers, and a receipt template; it must be removed properly, not left live.
3. **Log out** of all sessions and clear the `moquiLoginKey` cookie on test machines.
4. Confirm **MARUTHI (Org `100000`) was never touched** during the run.
5. Attach the completed run sheet(s) and any defect IDs to this part's test report.

---

14. Known defects & resolutions (from the hardening pass on 2026-06-30)

Resolved (deployed)

Ref	Issue	Resolution
R-1	Org ID typed in lower/mixed case failed the lookup (LOGIN-013)	Login now tries the value as typed, then the uppercased form
R-2	Blank / invalid Org-ID errors didn't display (silent bounce)	Switched to `ec.message.addError` so the message renders (a CDATA `&&` typo introduced during this fix briefly 500'd login and was corrected)
R-3	Subdomain case-collision, no format/length rules, no reserved words (ONB-012/013/014/015)	New `validate#Subdomain` service: lowercase canonicalisation, 3–30 char format, no edge/double hyphen, reserved-word block, uniqueness across tenants **and** org codes — shared by the live check and provisioning
R-4	Password rule under-stated (ONB-023)	Field now states "≥8 chars, 1 number, 1 special char"
R-5	Duplicate email only checked against tenants	Provisioning now also rejects an email already used by any user account, and lowercases the email
R-6	"Reserved subdomains / length / lockout" were open questions	Answered: reserved+length now enforced (R-3); lockout is the framework default **3 failures → 5-min disable**
R-7	**D-1: org-membership gate bypassed** (any valid user reached the dashboard with any Org ID)	**FIXED & verified** — see below

✅ D-1 — RESOLVED: org-membership gate now enforces (without locking out tenants)

Was: the gate set `orgValidationFailed = true` then `return`ed early inside an inline `<script>`; Moqui does **not** sync context variables across an early `return`, so the flag never reached the outer `<if>` and login proceeded for anyone.

Fix: rewrote the validation as structured `if/else` (no early `return`, so the flag propagates) and exempted platform super-admins (`isInGroup("ADMIN")`, who operate cross-tenant).

Why it's safe for the live tenant: investigation corrected an earlier wrong assumption — every existing active-org user **does** have the `PrtEmployee` membership, just from their *person* party (MARUTHI 100000/100410/100411 → person parties 100002/100765/100766 → `PrtEmployee` of 100000; the zenith_admin family → `PrtEmployee` of ORG_ZETA). So the gate passes for all of them via membership; no backfill was needed.

Verified on production:

- Non-member (john.sales + `maruthi`) → **blocked**, "does not belong", bounced to login ✓
- Invalid Org ID → **blocked**, "Invalid Organization ID" ✓
- Super-admin (john.doe, `ADMIN`) → allowed, **not** pinned to any org ✓
- Real member (john.sales into a throwaway-coded `ORG_ZIZI_RETAIL`, typed lowercase) → **allowed**, active org set ✓
- **All three real MARUTHI users** (`admin@maruthi.com`, `cashier1@maruthi.com`, `cashier2@maruthi.com`) → the gate's exact verdict, run against their real records, is **ALLOW(member)** for Org ID `MARUTHI` and lowercase `maruthi` alike (read-only admin diagnostic replaying the gate logic; no passwords needed).
- **Full end-to-end login on org 100000** — a throwaway QA user wired as a genuine `PrtEmployee` member of MARUTHI was driven through the **actual** `/Login` **form** (real password + gate): Org `MARUTHI` → **dashboard**, lowercase `maruthi` → **dashboard**, wrong org (correct password) → **blocked**, and the member branch correctly set `ACTIVE_ORGANIZATION=100000`. The throwaway account was then deleted (verified zero residue; MARUTHI's three real users untouched). The belt-and-suspenders caveat is therefore **fully closed end-to-end**, including the real password path on the live tenant.

Containment note retained for history: even before the fix, cross-tenant **data** was protected (active-org wasn't re-set on the bad path); the defect was "authenticates when it shouldn't".

End of Part 1 — Login & Onboarding. Next parts (to be issued separately): Part 2 — POS Billing Terminal (sessions, cart, payments, hold/recall, discounts); Part 3 — Inventory & Products; Part 4 — Sales & Invoicing; Part 5 — Settings, Users & Roles; Part 6 — Subscriptions & Platform Billing.